

Generative AI Security Scoping Matrix

https://aws.amazon.com/ko/ai/security/generative-ai-scoping-matrix/?utm_source=chatgpt.com

Generative AI Security Scoping Matrix
→ Responsibility / ownership boundary
→ “Application, data, model 중 누가 무엇을 control하는가?”

Scope	AWS 분류	조직이 control하는 범위	Provider가 control하는 범위	조직의 주요 control focus — 원문 기반 해석
1	Consumer app	조직이 서비스에 제공하는 customer data와 사용 방식	AI application, training /fine-tuning data, pre-trained/fine-tuned model	Provider-side AI control을 직접 통제하기 어려우므로 acceptable-use policy, data classification/handling, DLP-접속 통제, 사용자 교육 등 consumer-side governance 에 집중
2	Enterprise app	Customer data, 조직의 user/access 및 사용 정책	AI application과 underlying model 영역은 주로 provider	Scope 1의 consumer-side control에 더해 enterprise agreement, contractual protection, provider security/privacy assurance, opt-out 및 data-use 조건 은 검토
3	Pre-trained model	자체 application + customer data , application interface, authentication, data access, usage policy 등	Pre-trained FM + provider training data	조직이 application을 직접 구축하므로 application security, IAM/authorization, input/output validation, RAG/tool access, logging/monitoring 이 조직의 직접 control boundary도 들어옴
4	Fine-tuned model	Scope 3 범위 + fine-tuning data + customized model	Base/pre-trained model 및 원래 training data	Scope 3 control에 더해 training/fine-tuning data protection, poisoning 방지, model artifact protection, customized model access 및 evaluation 까지 확대
5	Self-trained model	Application, data, training, model 전체	사실상 조직 외부의 model provider responsibility가 없음	이전 Scope에서 provider가 담당하던 영역까지 조직이 책임지므로 training pipeline, model security, model artifact, evaluation, deployment, monitoring 을 포함한 model lifecycle 전체 가 조직 control boundary